



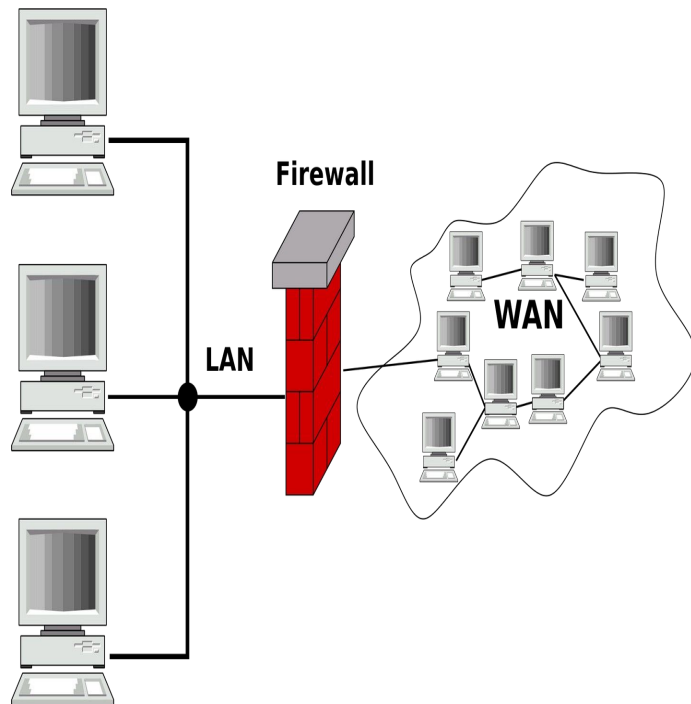
Operating Systems & Networks

CTEC1704C

Lecture – 16 : Network Security

Dr. Sameer Jha, SFHEA
Faculty of Computing
De Montfort University Cambodia

CTEC1704 - Networks



*Network
Security*



Lecture Content

- What is network security?
- Secure Socket Layer Using
- TLS
- Certificate Authorities
- Operational security



References & Reading

- Kurose & Ross; Computer Networking;
 - Chapter 8
- <https://www.upwork.com/hiring/development/understanding-it-security-and-network-security/>
- https://en.wikipedia.org/wiki/Diffie%E2%80%93Hellman_key_exchange#General_overview
- http://www.windowsecurity.com/articles/Secure_Socket_Layer.html
- https://en.wikipedia.org/wiki/Transport_Layer_Security
- <http://www.faqs.org/rfcs/rfc2246.html>
- http://www.webopedia.com/TERM/D/digital_certificate.html
- <https://www.acunetix.com/blog/articles/tls-vulnerabilities-attacks-final-part/>
- <https://computer.howstuffworks.com/firewall2.htm>

Post lecture discussion topics

- Compare and explain the difference between Encrypting a message string and Hashing a message string
- How does the Diffie-Hellman algorithm allow the exchange of secret keys over a public network?
- What is X509 used for?
- How is a digital certificate used to authenticate clients and servers to each other?

How does a CA become a CA, and what is their role?

Lecture Content

- What is network security?
- Secure Socket Layer
- Using TLS
- Certificate Authorities
- Operational security



What is network security?

- **Confidentiality**

- only sender & intended receiver should “understand” message contents
 - sender encrypts message
 - : receiver decrypts message

- **Authentication**

- sender & receiver want to confirm identity of each other



What is network security?

- **Message integrity**

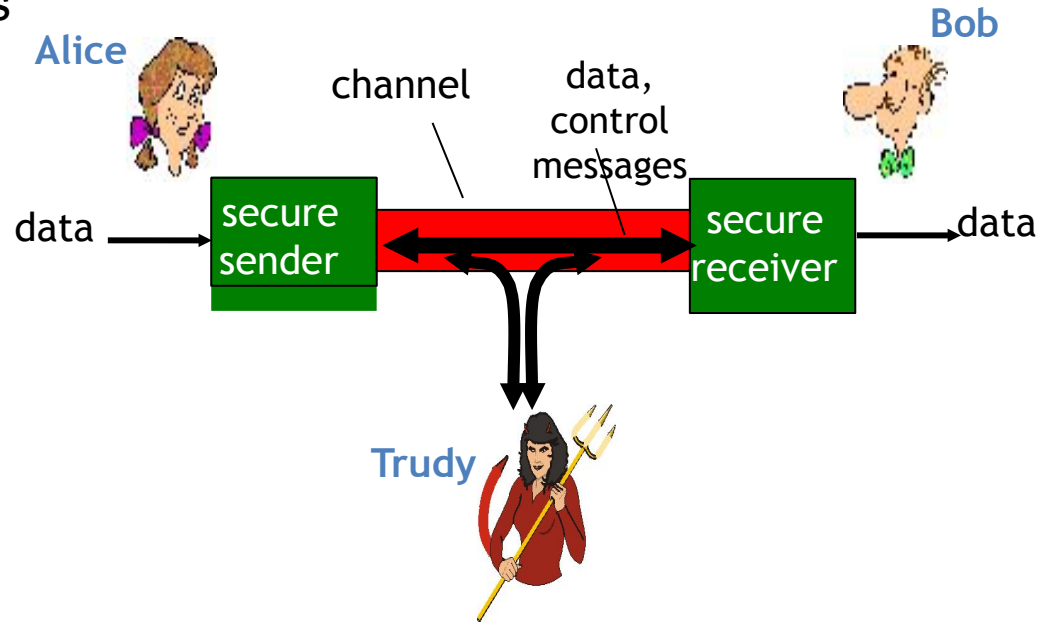
- Sender & receiver want to ensure message not altered
 - in
 - transit post
- if it was altered, it should be possible to detect alterations

- **Access and availability**

- services must be accessible and available to users
- Quality of Service agreements

Friends and enemies: Alice, Bob, Trudy

- Bob & Alice want to communicate “securely”
- Trudy (intruder) may intercept, delete, add, edit messages





What can a “bad guy” do?

- Eavesdro
 - p
 - intercept messages
 - actively insert messages into connection
- Impersonate
 - fake (spoof) source address (or other fields) in
- Hijack
 - k
 - “take over” ongoing connection by removing sender or receiver, inserting himself in place
- Denial of Service (DDoS)
 - prevent service from being used by others . by overloading resources

Lecture Content

- What is network security?
- **Secure Socket Layer Using**
- TLS
- Certificate Authorities
- Operational security



- Cryptographic software
- Encrypted tunnel between client & server
- Agreed encryption algorithm
- Provides application programming interface (API) to applications
 - C, PHP & Java/Scala SSL
- libraries/classes available

Multiple SSL protocols:

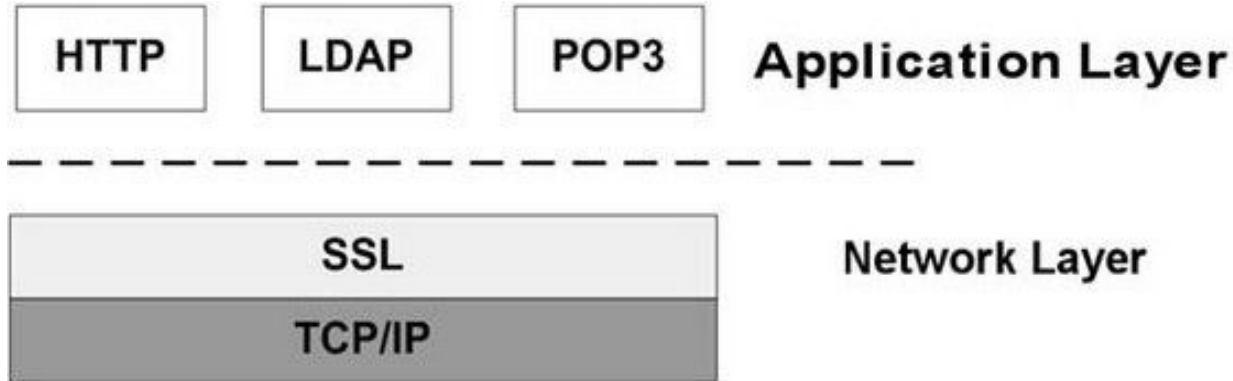
- SSL 1.0 – SSL 2.0 – SSL 3.0
- TLS 1.0 – TLS 1.3

SSL Summarised

- Authenticate the server to the client
- Allow the client and server to select the cryptographic algorithms, or ciphers, that they both support
- Optionally authenticate the client to the server
- Use public-key encryption techniques to generate shared secrets
- Establish an encrypted SSL connection

SSL

- Netscape created SSL for HTTP, LDAP & POP3 only





SSL Architecture

SSL handshake protocol	SSL cipher change protocol	SSL alert protocol	Application Protocol (eg. HTTP)
SSL Record Protocol			
TCP			
IP			

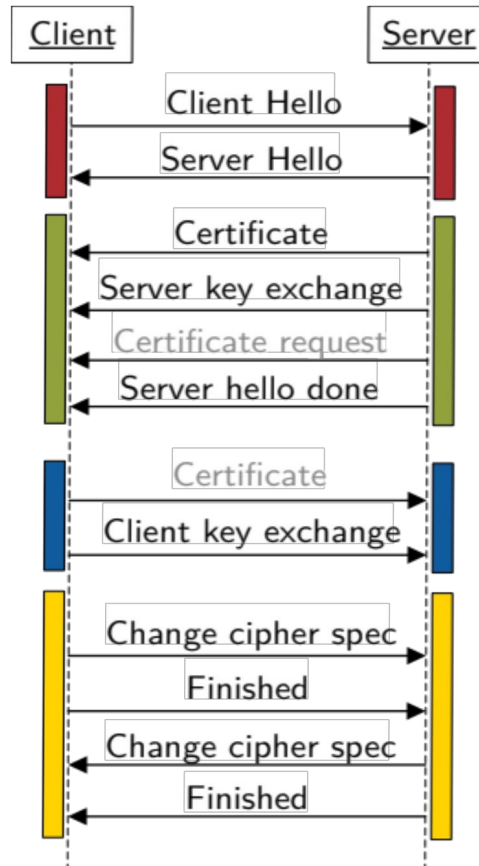
- 2 Layers:
 - Data security
 - SSL Record Protocol
 - Establish the connection
 - SSL Handshake Protocol
 - SSL ChangeCipher Spec Protocol
 - SSL Alert Protocol



SSL Record Protocol

- Defines data transmit format
 - Chunking the data from Application layer fixed length
 - Compress
 - the data
 - Add Message Authentication Code
 - • calculated with the help of Integrity Key Encrypt the packets
 - • now in chunks Add SSL header

SSL/TLS Handshake Protocol



- **Phase 1: Establishing security capabilities**
 - Client offers TLS version, list of ciphers, compression methods
 - Server chooses TLS version, cipher, compression method
- **Phase 2: Server authentication and key exchange**
 - Server sends certificate and key exchange parameters
 - Optional: server requests client certificate
- **Phase 3: Client authentication, key exchange**
 - Optional: client sends certificate
 - Client sends key exchange parameters
- **Phase 4: Finish**
 - Confirmation of cipher suites
 - Everything hereafter is encrypted

SSL Change Cipher Spec Protocol

- Change the encryption being used by the client and server
- Normally part of the handshake process to switch to symmetric key encryption
- Single message that tells the peer that the sender wants to change to a new set of keys
 - created from information exchanged by the handshake protocol



SSL Alert Protocol

- Signals problems with an SSL session
 - Messages convey the severity of the message and a description of the alert

Upon transmission or receipt of a fatal alert message, both parties immediately close the connection



SSL Alert Protocol

- The client and the server must communicate that the connection is ending to avoid a truncation attack
 - either party may initiate the exchange of closing messages
 - normal termination occurs when the `close_notify` message is sent
 - message notifies the recipient that the sender will not send any more messages on this connection
 - session becomes unresumable if any connection is terminated without a proper *close_notify* message



Certificate Exchange

- Server sends certificate to the client for authentication
 - one or a chain of X509 certificates
 - necessary for authentication of both the server and the certification path towards a trusted certification official of the certifying body for the server
- Server can request a certificate from the client
 - this step is not obligatory

TLS

- Transport Layer Security is a replacement (update) of SSL
 - SSL is now largely deprecated
- TLS connections may also be based upon Diffie-Hellman
 - or a similar key exchange algorithm

Lecture Content

- What is network security?
- Secure Socket Layer **Using**
- **SSL/TLS** Certificate
- Authorities Operational
- security

- Browser requests a secure page
- Web server sends its public key with its certificate
- The browser checks that the certificate was issued by a trusted party
- Browser then uses the public key to encrypt a random symmetric encryption key and sends it to the server with the encrypted URL required as well as other encrypted
- http data

- Web server decrypts the symmetric encryption key using its private key and uses the symmetric key to decrypt the URL and http data
- Web server sends back the requested html document and http data encrypted with the symmetric key



https1.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

Apply a display filter ... <Ctrl-/> Expression...

	Destination	Protocol	Length	Info
50	192.168.150.60	TCP	74	59216 → 443 [SYN] Seq=0 Win=5840 Len=0 MSS=1460 SACK_PERM=1 TSval=23897 TSecr=0 WS=2
60	192.168.150.50	TCP	74	443 → 59216 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM=1 TSval=24905 TSecr=23...
50	192.168.150.60	TCP	66	59216 → 443 [ACK] Seq=1 Ack=1 Win=5840 Len=0 TSval=23897 TSecr=24905
50	192.168.150.60	SSLv2	168	Client Hello
60	192.168.150.50	TCP	66	443 → 59216 [ACK] Seq=1 Ack=103 Win=5792 Len=0 TSval=24905 TSecr=23897
60	192.168.150.50	TLSv1	1278	Server Hello, Certificate, Server Key Exchange, Server Hello Done
50	192.168.150.60	TCP	66	59216 → 443 [ACK] Seq=103 Ack=1213 Win=8264 Len=0 TSval=23901 TSecr=24905
50	192.168.150.60	TLSv1	264	Client Key Exchange, Change Cipher Spec, Encrypted Handshake Message
60	192.168.150.50	TLSv1	125	Change Cipher Spec, Encrypted Handshake Message
50	192.168.150.60	TLSv1	695	Application Data
60	192.168.150.50	TLSv1	630	Application Data, Application Data, Application Data, Application Data
50	192.168.150.60	TCP	66	59216 → 443 [FIN, ACK] Seq=930 Ack=1836 Win=10688 Len=0 TSval=23905 TSecr=24905
60	192.168.150.50	TLSv1	103	Encrypted Alert
50	192.168.150.60	TCP	54	59216 → 443 [RST] Seq=931 Win=0 Len=0

Transmission Control Protocol, Src Port: 59216, Dst Port: 443, Seq: 1, Ack: 1, Len: 102

Secure Sockets Layer

- SSLv2 Record Layer: Client Hello
 - [Version: SSL 2.0 (0x0002)]
 - Length: 100
 - Handshake Message Type: Client Hello (1)
 - Version: TLS 1.0 (0x0301)
 - Cipher Spec Length: 75
 - Session ID Length: 0
 - Challenge Length: 16
 - Cipher Specs (25 specs)
 - Cipher Spec: TLS_DHE_RSA_WITH_AES_256_CBC_SHA (0x000039)
 - Cipher Spec: TLS_DHE_DSS_WITH_AES_256_CBC_SHA (0x000038)

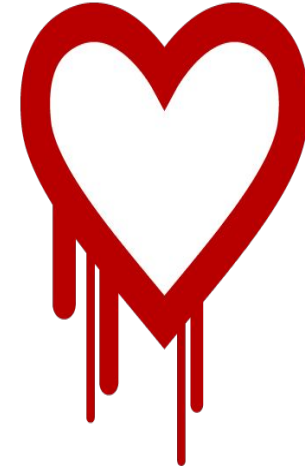
0000 de d8 07 82 9e 8b 72 55 eb 91 ad 08 08 00 45 00ru.....E..

2025-2 https1.pcap Packets: 14 · Displayed: 14 (100.0%) Profile: Default



SSL Vulnerabilities

- Famously – the Heartbleed Bug⁻ OpenSSL: implementation error
 - CVE-2014-0160
 - <http://heartbleed.com/>
- Other well-known bugs: Poodle
 - Beast
 - Crime
- <https://www.acunetix.com/blog/articles/tls-vulnerabilities-attacks-final-part/>



Lecture Content

- What is network security?
- Secure Socket Layer Using
- **SSL/TLS Certificate**
- **Authorities Operational**
- security

- **Who are they?**
- Why are they needed?
- Are they secure?
- Alternatives

- Who are they?
- **Why are they needed?**
- Are they secure?
- Alternatives

- Who are they?
- Why are they needed?
- **Are they secure?**
- Alternatives

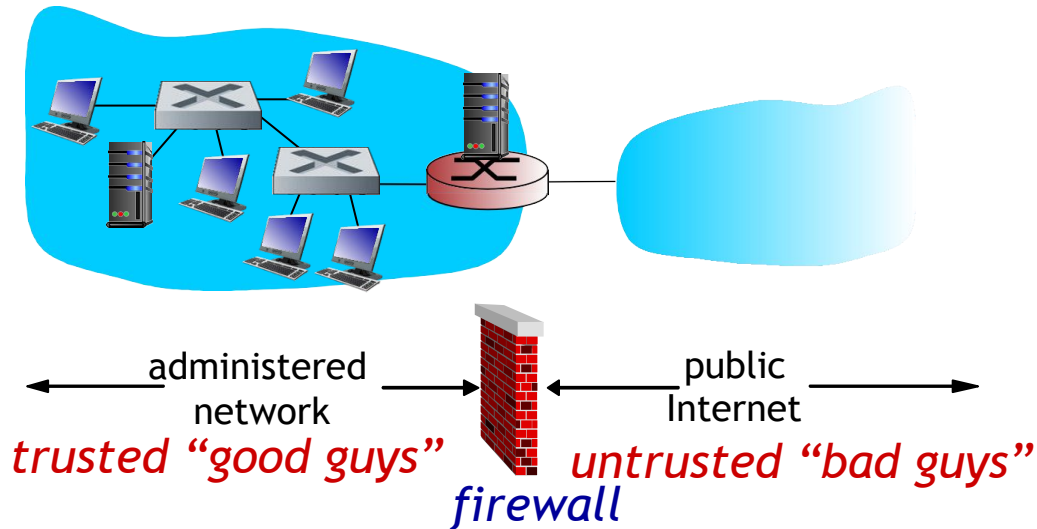
- Who are they?
- Why are they needed?
- Are they secure?
- **Alternatives**

Lecture Content

- What is network security?
- Secure Socket Layer Using
- SSL/TLS
- Certificate Authorities
- **Operational security**

Firewalls

- Isolate organisation's internal network from larger Internet, allowing some packets to pass, blocking others



Firewalls

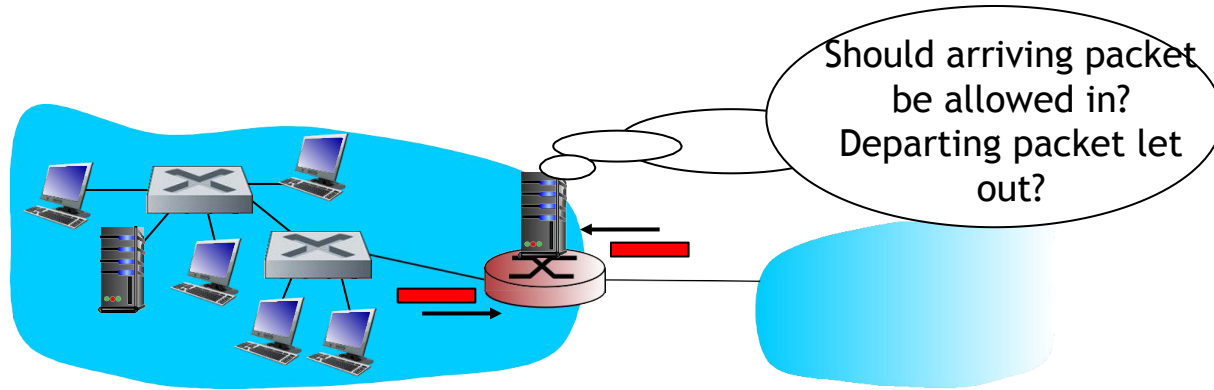
- Prevent denial of service attacks:
 - SYN flooding
 - attacker establishes many bogus TCP connections
 - no resources left for “real” connections
- Prevent illegal modification/access of internal data
 - eg attacker replaces CIA’s homepage with something else
- Allow only authorized access to inside network
 - set of authenticated users/hosts

Firewalls

- Three types of firewalls:
 - stateless packet filters
 - stateful packet filters
 - application gateways



Stateless packet filtering



- Internal network connected to Internet via router firewall
- Router filters packet-by-packet, decision to forward/drop packet based on:
 - source IP address, destination IP address
 - TCP/UDP source and destination port numbers
 - ICMP message type
 - TCP SYN and ACK bits



Stateless packet filtering: example

- Example 1
 - block incoming and outgoing datagrams with IP protocol field = 17 and with either source or dest port = 23
 - Result
 - all incoming, outgoing UDP flows and telnet connections are blocked



Stateless packet filtering: example

- Example 2
 - block inbound TCP segments with ACK=0
 - Result
 - prevents external clients from making TCP connections with internal clients
 - but allows internal clients to connect to outside



Stateless packet filtering: examples

<i>Policy</i>	<i>Firewall Setting</i>
No outside Web access	Drop all outgoing packets to any IP address, port 80
No incoming TCP connections, except those for institution's public Web server only	Drop all incoming TCP SYN packets to any IP except 130.207.244.203, port 80
Prevent Web-radios from eating up the available bandwidth	Drop all incoming UDP packets - except DNS and router broadcasts.
Prevent your network from being used for a smurf DoS attack	Drop all ICMP packets going to a "broadcast" address (e.g. 130.207.255.255).
Prevent your network from being tracerouted	Drop all outgoing ICMP TTL expired traffic



Access Control Lists

- ACL: table of rules, applied top to bottom to incoming packets: (action, condition) pairs

action	source address	dest address	protocol	source port	dest port	flag bit
allow	222.22/16	outside of 222.22/16	TCP	> 1023	80	any
allow	outside of 222.22/16	222.22/16	TCP	80	> 1023	ACK
allow	222.22/16	outside of 222.22/16	UDP	> 1023	53	---
allow	outside of 222.22/16	222.22/16	UDP	53	> 1023	----
deny	all	all	all	all	all	all



Stateful packet filtering

- stateless packet filter: heavy handed tool
 - admits packets that “make no sense,” e.g., dest port = 80, ACK bit set, even though no TCP connection established:

action	source addres s	dest address	protocol	source port	dest port	flag bit
allow	outside of 222.22/16	222.22/16	TCP	80	> 1023	ACK

- stateful packet filter: track status of every TCP connection
 - track connection setup (SYN), teardown (FIN): determine whether incoming, outgoing packets “makes sense”
 - timeout inactive connections at firewall: no longer admit packets



Stateful packet filtering

- ACL augmented to indicate need to check connection state table before admitting packet

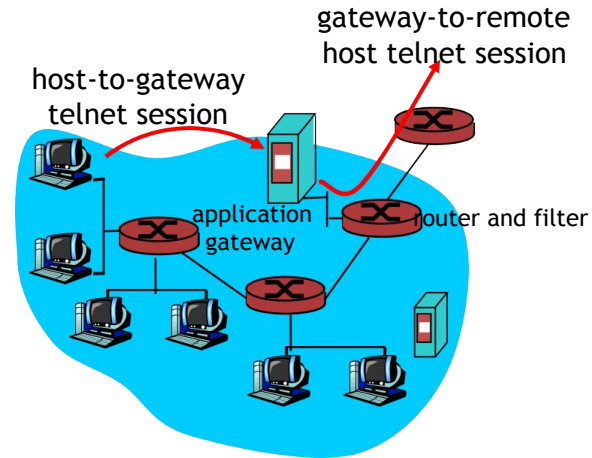
action	source address	dest address	proto	source port	dest port	flag bit	check conxion
allow	222.22/16	outside of 222.22/16	TCP	> 1023	80	any	
allow	outside of 222.22/16	222.22/16	TCP	80	> 1023	ACK	X
allow	222.22/16	outside of 222.22/16	UDP	> 1023	53	---	
allow	outside of 222.22/16	222.22/16	UDP	53	> 1023	----	X
deny	all	all	all	all	all	all	



Application Gateways

Filters packets on application data as well as on IP/TCP/UDP fields

- Example: allow select internal users to telnet outside
 1. require all telnet users to telnet through gateway
 2. for authorized users, gateway sets up telnet connection to destination host
 - Gateway relays data between 2 connections
 3. router filter blocks all telnet connections not originating from gateway



Limitations of Firewalls & Gateways

- IP spoofing: router can't know if data “really” comes from claimed source
- If multiple applications need special treatment, each has own app. gateway
- Client software must know how to contact gateway
 - eg must set IP address of proxy in Web browser
- Filters often use all or nothing policy for UDP
- Tradeoff:
 - degree of communication with outside world, level of security
 - many highly protected sites still suffer from attacks

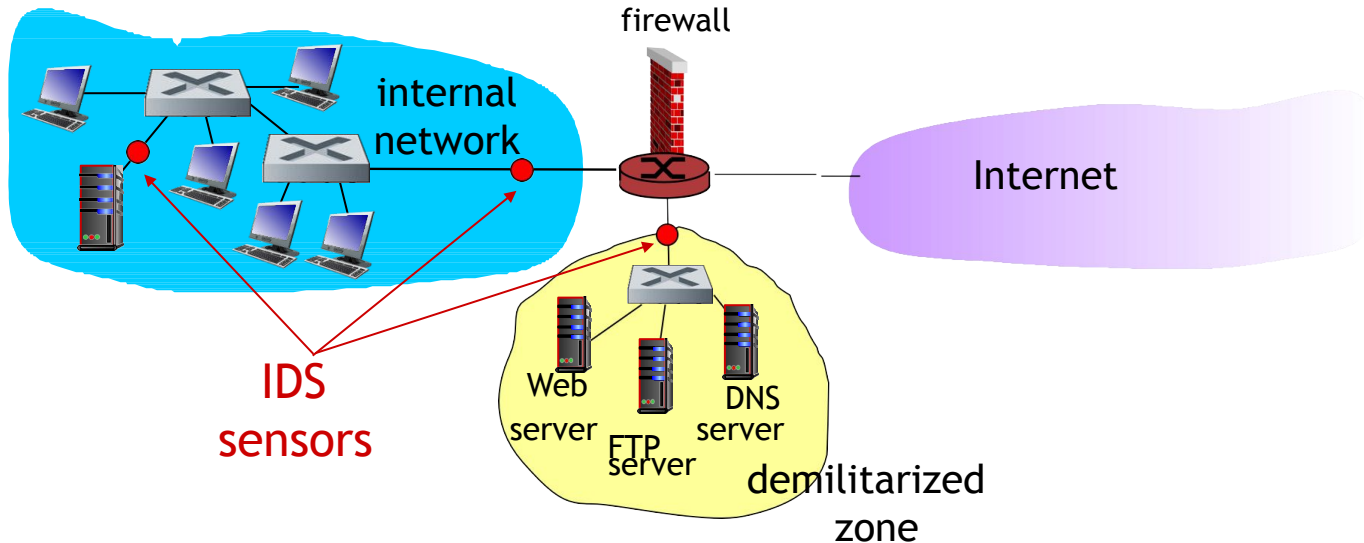


Intrusion Detection Systems

- packet filtering:
 - operates on TCP/IP headers only
 - no correlation check among sessions
- IDS: intrusion detection system
 - deep packet inspection: look at packet contents (e.g., check character strings in packet against database of known virus, attack strings)
 - examine correlation among multiple packets
 - port scanning
 - network mapping
 - DoS attack

Intrusion Detection Systems

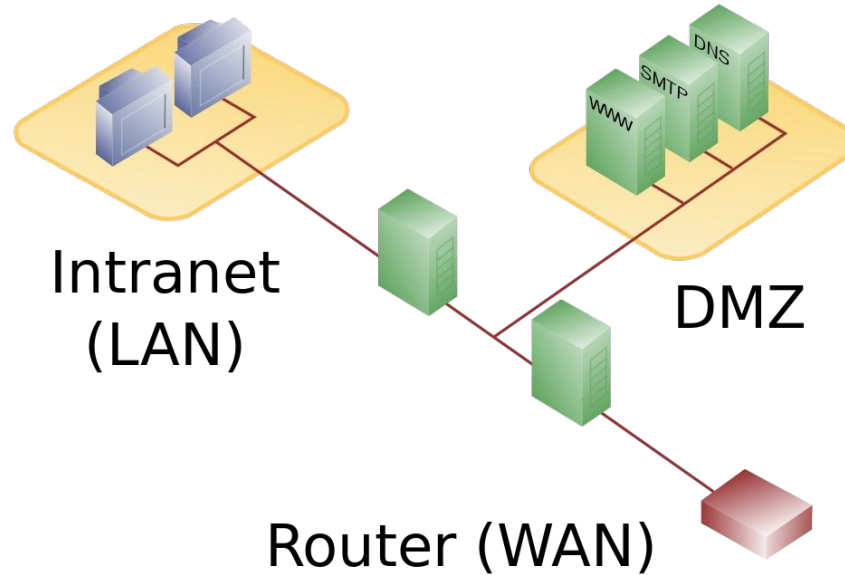
- Multiple IDSs: different types of checking at different locations





Demilitarised Zones

- A demilitarised zone (DMZ) is part of your network that exposes external facing services (mail, web) to a wider untrusted net (eg. the internet)



Lecture Content

- What is network security?
- Secure Socket Layer Using
- SSL/TLS
- Certificate Authorities
- Operational security



Thank You!



Operating Systems & Networks

CTEC1704C

Lecture – 17 : DHCP & the DORA Cycle

Dr. Sameer Jha, SFHEA
Faculty of Computing
De Montfort University Cambodia



<https://web-tech.fr/wp-content/uploads/2019/03/dhcp.jpg>

DHC

- DHCP
 - DORA cycle
 - messages
- Other Issues
- Configuring a DHCP server



References & Reading

Kurose & Ross; Computer Networking;

- Chapter 8

https://en.wikipedia.org/wiki/Dynamic_Host_Configuration_Protocol
<https://tools.ietf.org/html/rfc1531>

<http://debianhelp.co.uk/dhcp.htm>

<http://www.garykessler.net/library/dhcp.htm>

•



Post lecture discussion topics

- Compare the three alternative techniques used by a DHCP server to allocate IP addresses
- Summarise the flow of messages that occurs when a host requests an IP address from a DHCP server
- Describe each of the three main categories by which a DHCP server may be attacked



- **DHCP**
 - DORA cycle
 - messages
- Other Issues



- . Dynamically configures IP addresses
- . Central DHCP server
- Facilitates expanding a network
- Server manages a pool of IP addresses
- IP address is “leased” to a client machine
- Originally BOOTP protocol
 - Updated the RARP protocol



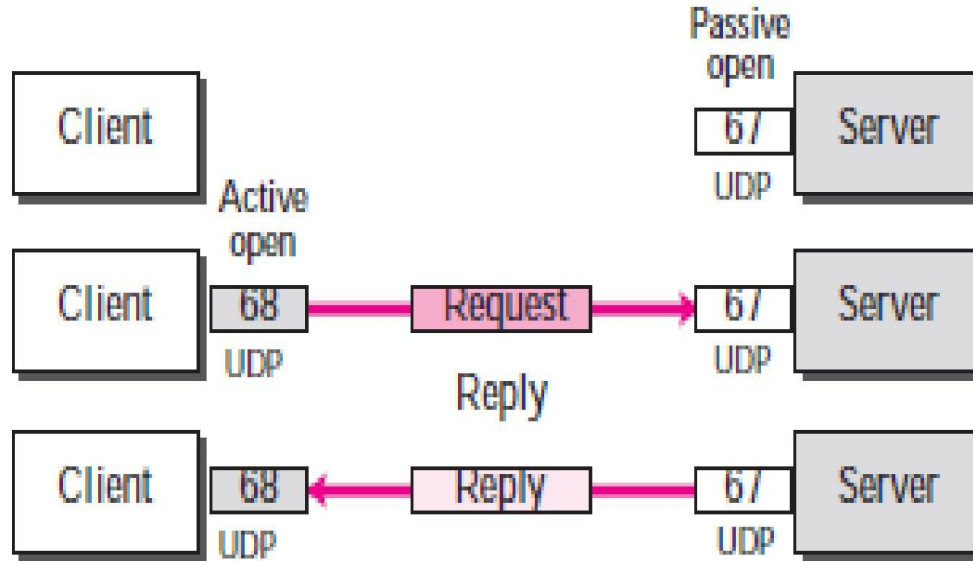
- . Client machine requests an IP at boot
- . Client & DHCP server
 - can be on same subnet
 - normally just 1 server per subnet
 - DHCP Relay agent manages requests to remote subnets



IP Allocation

- . dynamic allocation
- . automatic allocation
- . static allocation

DHCP Ports



- UDP
- port 67 - sending messages to the server
- port 68 - returning messages to the client
- DHCP communications are connectionless

—

stateless

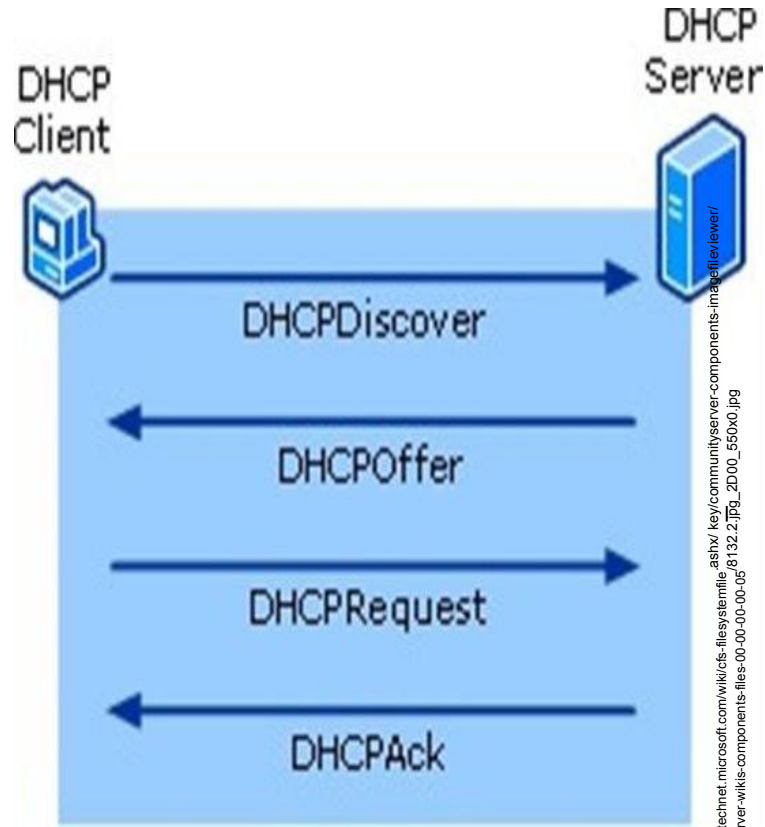
<https://www.google.com/search?q=dhcp+ports&rlz=1C1QKqUit-5pD57NFTEZ0bbyhziGud8KiNeSOZqNCYUm3YGxMsN5wt2DsL60mWVIFtwnlhOHplT8XyeadCATA>

- DHCP
 - **DORA cycle**
 - messages
- Other Issues
- Configuring a DHCP server



DHCP DORA Cycle

- Four basic phases
 - IP discovery
 - IP lease offer
 - IP request
 - IP lease acknowledgement
- DORA
 - discovery, offer, request, acknowledgement





DHCP Discover

- Client broadcasts messages on the physical subnet to discover available DHCP server(s)
- Packet has broadcast destination of 255.255.255.255
 - or specific subnet broadcast address



DHCP Discover

- Client can request its last-known IP address
 - Authoritative/non-authoritative DHCP servers may refuse



DHCPDISCOVER

UDP Src=0.0.0.0 sPort=68

Dest=255.255.255.255 dPort=67

OP	HTYPE	HLEN	HOPS
0x01	0x01	0x06	0x00
XID			
0x3903F326			
SECS		FLAGS	
0x0000		0x0000	
CIADDR (Client IP Address)			
0x00000000			
YIADDR (Your IP Address)			
0x00000000			
SIADDR (Server IP Address)			
0x00000000			
GIADDR (Gateway IP Address)			
0x00000000			
CHADDR (Client Hardware Address)			
0x00053C04			
0x8D590000			
0x00000000			
0x00000000			
192 octets of 0s, or overflow space for additional options. BOOTP legacy			
Magic Cookie			
0x63825363			
DHCP Options			
DHCP option 53: DHCP Discover			
DHCP option 50: 192.168.1.100 requested			
DHCP option 55: Parameter Request List:			
Request Subnet Mask (1), Router (3), Domain Name (15), Domain Name Server (6)			

DHCP

Discover



DHCP Offer

- When request arrives:
 - IP reserved for client
 - offers IP lease to client
- Uses CHADDR field to determine configuration details



DHCP OFFER

UDP Src=192.168.1.1 sPort=67
Dest=255.255.255.255 dPort=68

OP	HTYPE	HLEN	HOPS
0x02	0x01	0x06	0x00
XID			
0x3903F326			
SECS		FLAGS	
0x0000		0x0000	
CIADDR (Client IP Address)			
0x00000000			
YIADDR (Your IP Address)			
0xC0A80164			
SIADDR (Server IP Address)			
0xC0A80101			
GIADDR (Gateway IP Address)			
0x00000000			
CHADDR (Client Hardware Address)			
0x00053C04			
0x8D590000			
0x00000000			
0x00000000			
192 octets of 0s. BOOTP legacy			
Magic Cookie			
0x63825363			
DHCP Options			
DHCP option 53: DHCP Offer			
DHCP option 1: 255.255.255.0 subnet mask			
DHCP option 3: 192.168.1.1 router			
DHCP option 51: 86400s (1 day) IP lease time			
DHCP option 54: 192.168.1.1 DHCP server			
DHCP option 6: DNS servers 9.7.10.15, 9.7.10.16, 9.7.10.18			

DHCP Offer



DHCP Request

- Client broadcasts Request
- Selects single offer
- Other servers back-off



DHCPREQUEST

UDP Src=0.0.0.0 sPort=68
Dest=255.255.255.255 dPort=67

OP	HTYPE	HLEN	HOPS
0x01	0x01	0x06	0x00
XID			
0x3903F326			
SECS		FLAGS	
0x0000		0x0000	
CIADDR (Client IP Address)			
0x00000000			
YIADDR (Your IP Address)			
0x00000000			
SIADDR (Server IP Address)			
0xC0A80101			
GIADDR (Gateway IP Address)			
0x00000000			
CHADDR (Client Hardware Address)			
0x00053C04			
0x8D590000			
0x00000000			
0x00000000			
192 octets of 0s. BOOTP legacy			
Magic Cookie			
0x63825363			
DHCP Options			
DHCP option 53: DHCP Request			
DHCP option 50: 192.168.1.100 requested			
DHCP option 54: 192.168.1.1 DHCP server.			

DHCP

Request



DHCP Acknowledgement

- Server sends DHCPACK
 - lease duration
 - etc
- Client configures NIC with received parameters
- Client can use ARP to prevent IP conflicts



DHCP Ack

DHCPACK			
UDP Src=192.168.1.1 sPort=67 Dest=255.255.255.255 dPort=68			
OP	HTYPE	HLEN	HOPS
0x02	0x01	0x06	0x00
XID			
0x3903F326			
SECS		FLAGS	
0x0000		0x0000	
CIADDR (Client IP Address)			
0x00000000			
YIADDR (Your IP Address)			
0xC0A80164			
SIADDR (Server IP Address)			
0xC0A80101			
GIADDR (Gateway IP Address switched by relay)			
0x00000000			
CHADDR (Client Hardware Address)			
0x00053C04			
0x8D590000			
0x00000000			
0x00000000			
192 octets of 0s. BOOTP legacy			
Magic Cookie			
0x63825363			
DHCP Options			
DHCP option 53: DHCP ACK			
DHCP option 1: 255.255.255.0 subnet mask			
DHCP option 3: 192.168.1.1 router			
DHCP option 51: 86400s (1 day) IP lease time			
DHCP option 54: 192.168.1.1 DHCP server			
DHCP option 6: DNS servers 9.7.10.15, 9.7.10.16, 9.7.10.18			



DHCP Releasing

- Client can send a release request
 - DHCP server releases the DHCP information
 - client deactivates its IP address
 - optional
 - client devices usually do not know when users unplug them from the network

DHCP Summary

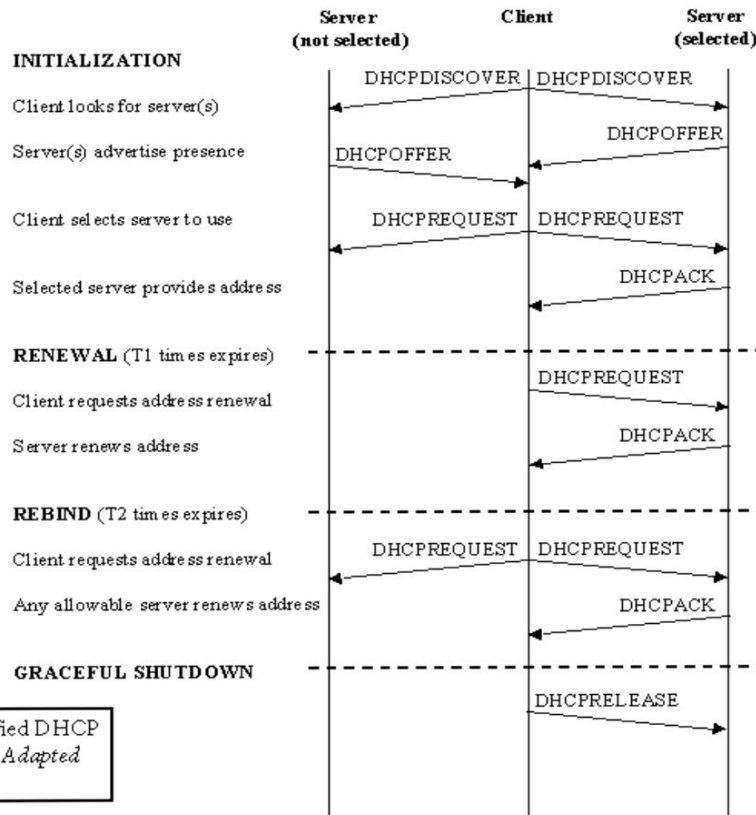


FIGURE 2. Simplified DHCP message exchange. *Adapted from RFC 2131.*



- DHCP
 - DORA cycle
 - messages
- **Other Issues**
- Configuring a DHCP server

Other Issues

- **Vendor identification**
- DHCP Relaying
- Confidentiality
- Reliability
- Security



Other Issues

- . Vendor identification
- . **DHCP Relaying**
- . Confidentiality
- . Reliability
- Security

Other Issues

- Vendor identification
- DHCP Relaying
- **Confidentiality**
- **Reliability**
- **Security**



- At 50% of lease time, client requests new lease
 - unicast
- If server unavailable, then client broadcasts a new DHCP request
 - for rebinding to work, new server must have accurate client information

If lease expires, client broadcasts DHCP discover as before



- . No authentication in use
- . Three main attack categories:
 - Unauthorized DHCP servers providing false information to clients
 - Unauthorized clients gaining access to resources
 - Resource exhaustion attacks from malicious DHCP clients



- Relay Agent Information Option
 - RFC 3046
 - Uses a tag as authentication token
 - But there are problems of managing keys for large numbers of DHCP clients

- DHCP
 - DORA cycle
 - messages
- Other Issues
- **Configuring a DHCP server**

Configuring DHCP Server

- /etc/dhcp/dhcpd.conf

```
option domain-name "test1.com";  
option domain-name-servers 192.0.0.1,  
194.2.0.50;  
option routers 192.0.0.151;  
default-lease-time 3600;  
subnet 192.0.0.0 netmask 255.255.255.0 {  
range 192.0.0.200 192.0.0.254;  
}
```

Static IP Address

```
host hostname {  
  hardware ethernet  
    00:B0:CF:8B:49:37; fixed-address  
    192.0.0.19;  
}
```



- /etc/network/interfaces

```
auto lo eth0  
iface lo inet loopback  
iface eth0 inet dhcp
```

Lecture Content

- DHCP
 - DORA cycle
 - messages
- Other Issues
- Configuring a DHCP server



Thank You!



Operating Systems & Networks

CTEC1704C

Lecture – 18 : The DNS System

Dr. Sameer Jha, SFHEA
Faculty of Computing
De Montfort University Cambodia



DN
S



- . Who runs the Internet?
- . DNS
- DNS Mechanism
- DNS Messages

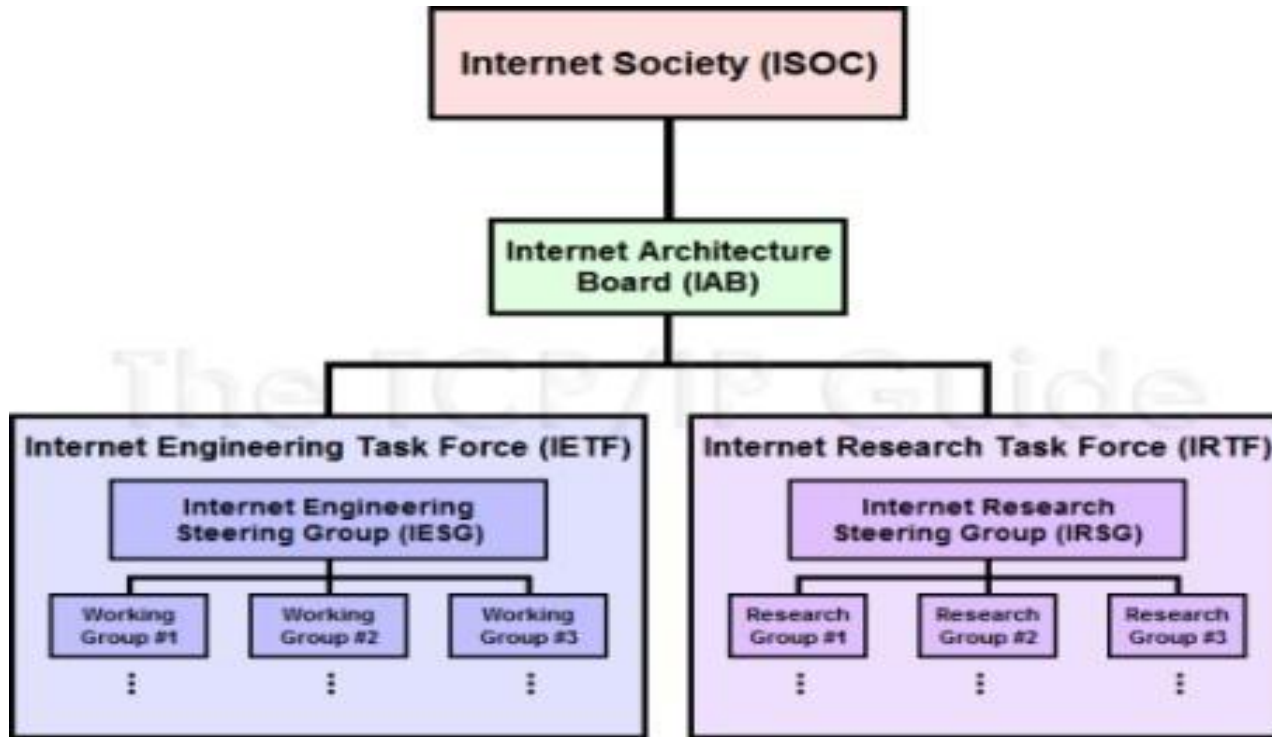


- Kurose & Ross; Computer Networking;
- https://en.wikipedia.org/wiki/Chapter_2_Domain_Name_System
- <https://likegeeks.com/linux-dns-server>
- <https://aws.amazon.com/route53/what-is-dns/#:~:text=The%20Internet's%20DNS%20system%20works,These%20requests%20are%20called%20queries./>
- <https://en.wikipedia.org/wiki/>



- Describe static DNS vs dynamic DNS
- Summarise the flow of messages to and from DNS servers when a browser accesses the <http://bbc.co.uk> web-site
 - Assume that the record for that web-server is not in the local DNS database
- Investigate recent DDoS attacks against DNS servers
 - What was the vulnerability in the DNS protocol that allowed the attack to succeed

- **Who runs the Internet?**
- DNS
- DNS Mechanism
- DNS Messages





- Internet Society (ISOC)
- Internet Architecture Board (IAB)
- Internet Engineering Steering Group (IESG)
- Internet Engineering Task Force (IETF)
- Internet Research Task Force (IRTF)
- Internet Corporation for Assigned Names and Numbers (ICANN)
 - Internet Assigned Numbers Authority (IANA)
 - Regional Internet Registry (RIR)



- Application layer:
 - W3C (World Wide Web Consortium)
- Physical layer
 - IEEE 802 standards



- Who runs the Internet?
- **DNS**
- DNS Mechanism
- DNS Messages

• The Internet maintains two separate namespaces

- IP Addresses

- Domain Names



- A business/personalised domain can be bought from a domain reseller
 - Domain registrar
- Registrar places entry for your DNS server in appropriate next level up server domain



- . Hierarchical distributed naming system
- . Essential component of the Internet
- . Any network connected resource
 - Internet/Intranet



- Maps textual domain names to IP addresses
- Eg
 - www.example.com
- Might become
 - 192.0.43.10
IPv4
 - 2001:500:88:200::10
IPv6



- Hierarchy of domains
 - Each domain has an authoritative name server
 - Authoritative name servers:
 - responsible for their supported domains
 - may delegate authority over subdomains to other name servers
- Mechanism
 - provides distributed and fault tolerant service
 - designed to avoid the need for a single central database



- Stores DNS resource records for a domain name
 - Start of Authority (SoA)
 - address (A or AAAA) records
 - name server (NS) records
 - mail exchanger (MX) records
 - reverse lookup pointer (PTR)
 - domain name aliases (CNAME)
 - canonical name



- . Defines the beginning of the authority DNS
- . zone Specifies the global parameters for the
- . zone One SOA record per zone
 - SOA record structure
 - . Serial number
 - . Primary name server (NS)
 - . DNS admin e-mail
 - . Refresh Rate
 - . Retry Rate
 - . Expire time
 - . Default
 - TTL



- Other fields now include
 - Domain Name System Security Extensions (DNSSEC)
 - . Authentication but not encryption
 - responsible person (RP)
 - Domain Name System-based Blackhole List (DNSBL)



- Each DNS server stores information about servers
 - including DNS servers
- Responds with answers to queries against its database

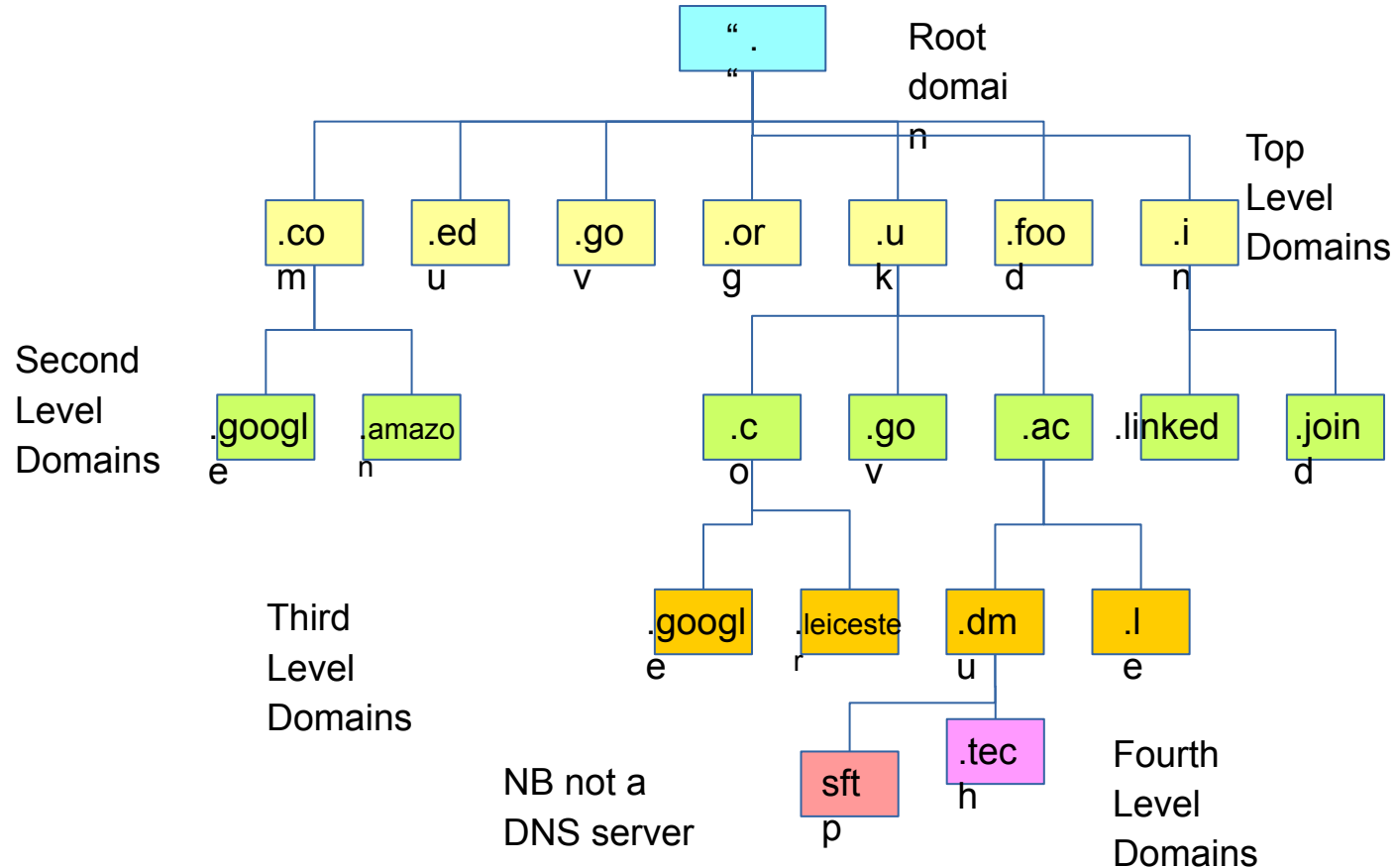


- Tree of domain names
- Each node or leaf in the tree has zero or more resource records
 - information associated with the domain name
- Tree sub-divides into zones beginning at the root zone



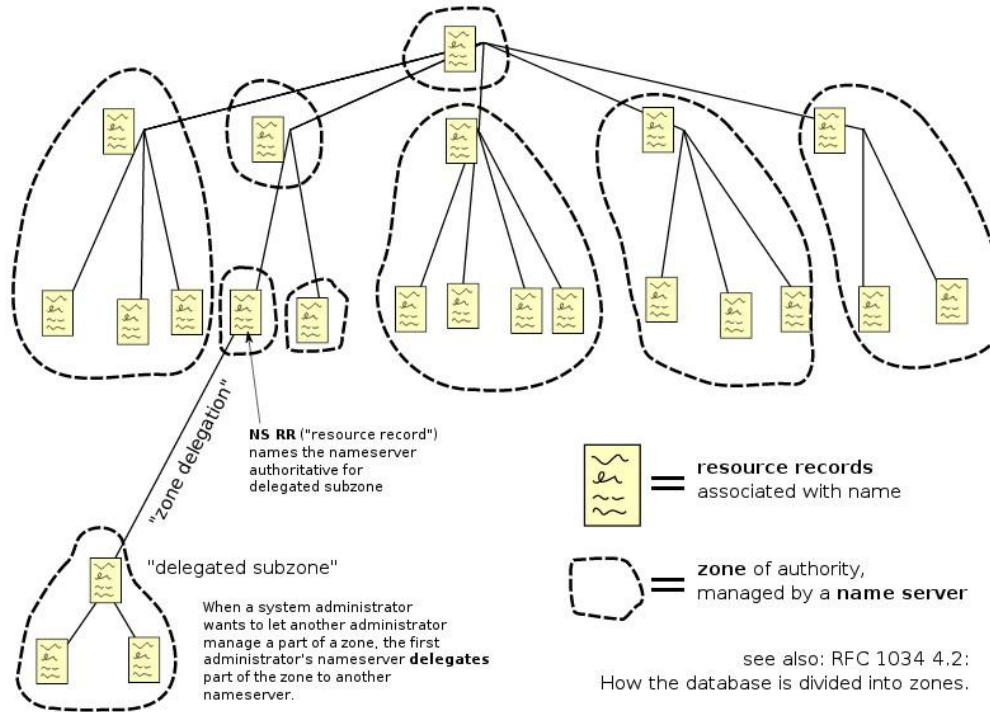
- IANA currently distinguishes the following groups of top-level domains
 - <https://www.iana.org/domains/root/db>
 - country-code top-level domains (ccTLD)
 - generic top-level domains (gTLD)
 - sponsored top-level domains (sTLD)
 - unsponsored top-level domains
 - infrastructure top-level domain (.arpa)

Domain Name Hierarchy





Domain Name Space





- Domain name registrars accredited by ICANN
- Each TLD maintained and serviced technically by an administrative organisation, operating a registry
- Registry responsible for maintaining the database of names registered within the TLD it administers
- Receives registration information from each domain name registrar authorized to assign names in the corresponding TLD
 - publishes the information using a special service, the WHOIS protocol



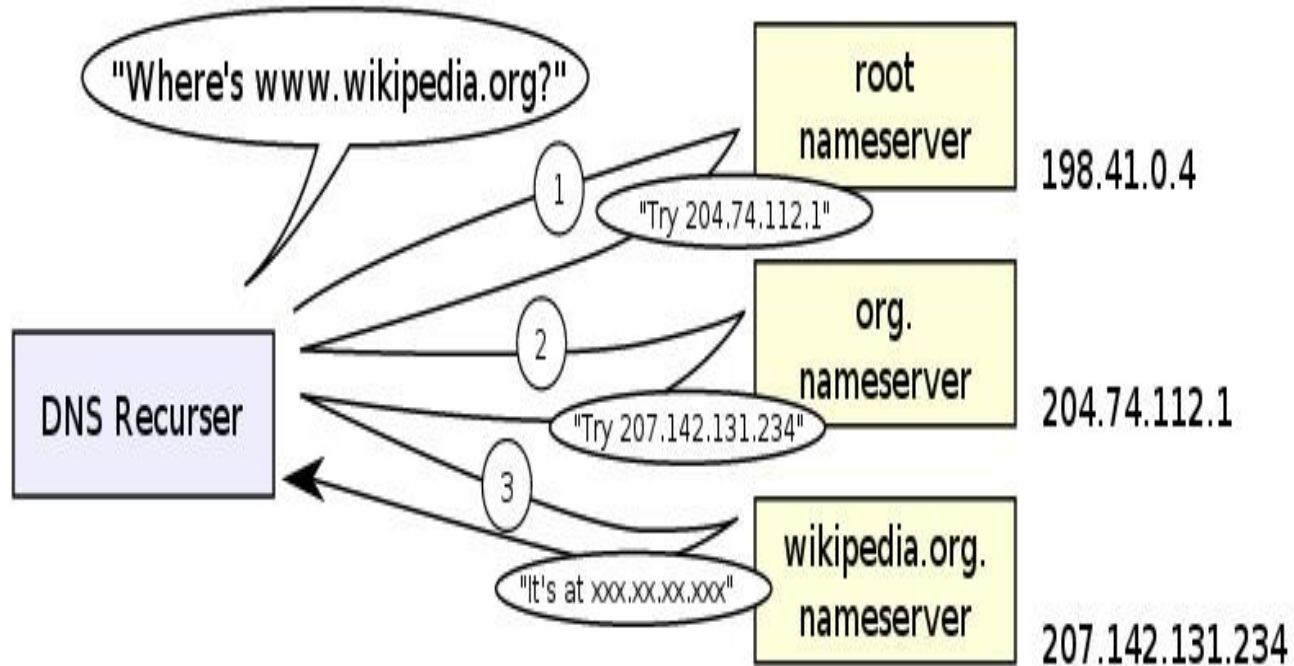
- Domain names comprises one or more labels
- Delimited by dots
- Max 127 labels
 - max 63 characters
- Total domain name max of 253 chars
 - chars are LDH
- NB www is optional!



- Gives answers that have been configured by an original source
 - domain administrator
 - dynamic DNS methods
- Returns answers to queries about domain names that have been specifically configured by the administrator
- Can be Primary or Secondary

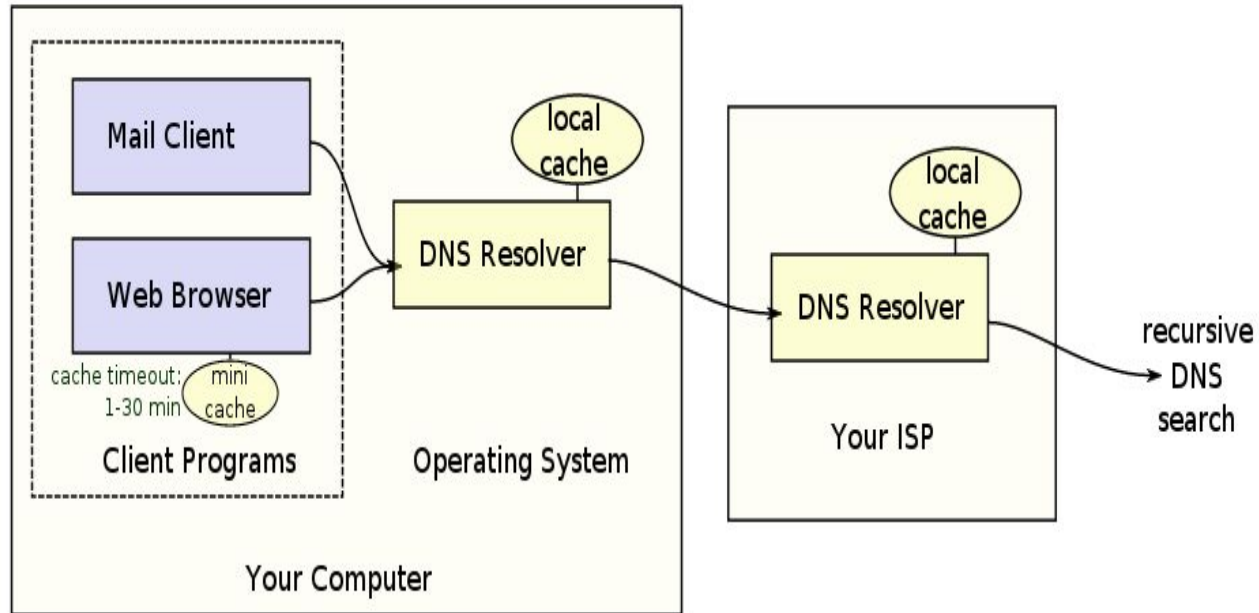


- . Who runs the Internet?
- . DNS
- **DNS Mechanism**
- DNS Messages





- Improve efficiency
- Reduce DNS traffic across the Internet
- Increase performance in end-user applications





Field	Description	Length (octets)
NAME	Name of the node to which this record pertains	(variable)
TYPE	Type of RR in numeric form (e.g. 15 for MX RRs)	2
CLASS	Class code	2
TTL	Count of seconds that the RR stays valid (The maximum is 231-1, which is about 68 years)	4
RDLENGTH	Length of RDATA field	2
RDATA	Additional RR-specific data	(variable)



- . Who runs the Internet?
- . DNS
- DNS Mechanism
- **DNS Messages**



- Client/server
- Stateless
- UDP segments

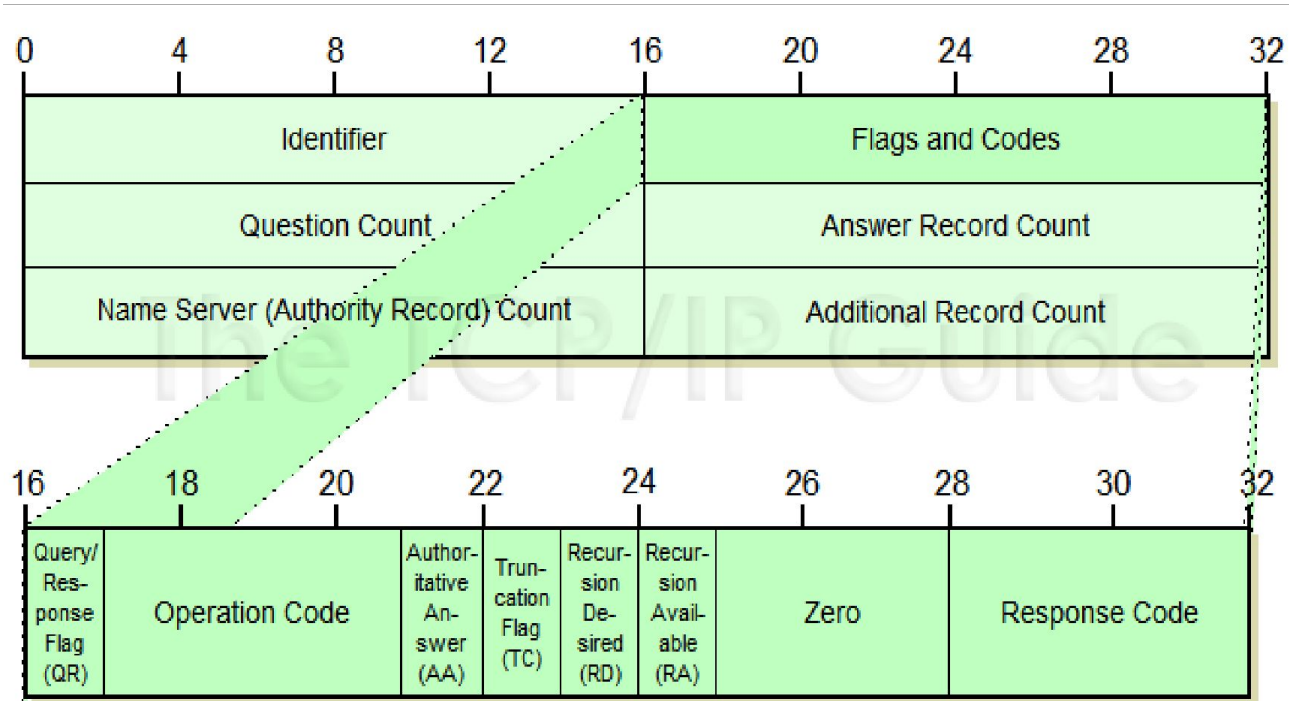


- Header
 - Contains fields that describe the type of message and provide important information about it
- Question
 - Also contains fields that indicate the number of entries in the other sections of the message
 - Carries one or more “questions” queries for information being sent to a DNS name server
- Answer
 - one or more resource records that answer the question(s) indicated in the Question section above



- Authority
 - one or more resource records that point to authoritative name servers that can be used to continue the resolution process
- Additional
 - one or more resource records that contain additional information related to the query that is not strictly necessary to answer the queries (questions) in the message

DNS Message Format



http://www.tcpipguide.com/free/t_DNSMessageHeaderandQuestionSectionFormat.htm

- ID 2 Identifier: A 16-bit identification field generated by the device that creates the DNS query. It is copied by the server into the response, so it can be used by that device to match that query to the corresponding reply received from a DNS server. This is used in a manner similar to how the Identifier field is used in many of the ICMP message types.
- QR 1/8 (1 bit) Query/Response Flag: Differentiates between queries and responses. Set to 0 when the query is generated; changed to 1 when that query is changed to a response by a replying server.
- Opcode 1/2 (4 bits) Specifies the type of query being carried
- AA 1/8 (1 bit) Authoritative Answer Flag: This bit is set to 1 in a response to indicate that the server that created the response is authoritative for the zone in which the domain name specified in the Question section is located. If it is 0, the response is non-authoritative
- C 1/8 (1 bit) Truncation Flag: When set to 1, indicates that the message was truncated due to its length being longer than the maximum permitted for the type of transport mechanism used. TCP doesn't have a length limit for messages, while UDP messages are limited to 512 bytes, so this bit being sent usually is an indication that the message was sent using UDP and was too long to fit. The client may need to establish a TCP session to get the full message. On the other hand, if the portion truncated was part of the Additional section, it may choose not to bother



- RD 1/8 (1 bit) Recursion Desired: When set in a query, requests that the server receiving the query attempt to answer the query recursively, if the server supports recursive resolution. The value of this bit is not changed in the response
- RA 1/8 (1 bit) Recursion Available: Set to 1 or cleared to 0 in a response to indicate whether the server creating the response supports recursive queries. This can then be noted by the device that sent the query for future use
- Z 3/8 (3 bits) Zero: Three reserved bits set to zero
- RCode 1/2 (4 bits) Set to zero in queries then changed by the replying server in a response to convey the results of processing the query. Used to indicate if the question was asked successfully, or if some sort of error occurred
- QDCount 2 Question Count: Specifies the number of questions in the Question section of the message
- ANCount 2 Answer Record Count: Specifies the number of resource records in the Answer section of the message
- NSCount 2 Authority Record Count: Specifies the number of resource records in the Authority section of the message
- ARCount 2 Additional Record Count: Specifies the number of resource records in the Additional section of the message



172.16.12.100	172.16.12.252	DNS	80 Standard query 0xf693 A client2.ctec.dmu.org
172.16.12.252	172.16.12.100	DNS	129 Standard query response 0xf693 A client2.ctec.dmu.org A 172.16.12.110 NS ns.ctec.dmu.org A ...
172.16.12.100	172.16.12.110	ICMP	98 Echo (ping) request id=0x7504, seq=1/256, ttl=64 (reply in 16)
172.16.12.110	172.16.12.100	ICMP	98 Echo (ping) reply id=0x7504, seq=1/256, ttl=64 (request in 15)
172.16.12.100	172.16.12.252	DNS	86 Standard query 0x3d44 PTR 110.12.16.172.in-addr.arpa
172.16.12.252	172.16.12.100	DNS	86 Standard query response 0x3d44 Server failure PTR 110.12.16.172.in-addr.arpa
172.16.12.100	172.16.12.252	DNS	86 Standard query 0x3d44 PTR 110.12.16.172.in-addr.arpa
172.16.12.252	172.16.12.100	DNS	86 Standard query response 0x3d44 Server failure PTR 110.12.16.172.in-addr.arpa
172.16.12.110	172.16.12.253	DHCP	342 DHCP Request - Transaction ID 0xba6d8531
172.16.12.253	172.16.12.110	DHCP	342 DHCP ACK - Transaction ID 0xba6d8531
172.16.12.100	172.16.12.110	ICMP	98 Echo (ping) request id=0x7504, seq=2/512, ttl=64 (reply in 24)
172.16.12.110	172.16.12.100	ICMP	98 Echo (ping) reply id=0x7504, seq=2/512, ttl=64 (request in 23)
172.16.12.100	172.16.12.252	DNS	86 Standard query 0x6db6 PTR 110.12.16.172.in-addr.arpa
172.16.12.252	172.16.12.100	DNS	86 Standard query response 0x6db6 Server failure PTR 110.12.16.172.in-addr.arpa
172.16.12.100	172.16.12.252	DNS	86 Standard query 0x6db6 PTR 110.12.16.172.in-addr.arpa
172.16.12.252	172.16.12.100	DNS	86 Standard query response 0x6db6 Server failure PTR 110.12.16.172.in-addr.arpa
172.16.12.120	172.16.12.253	DHCP	342 DHCP Request - Transaction ID 0x8f5f0e6f
172.16.12.253	172.16.12.120	DHCP	342 DHCP ACK - Transaction ID 0x8f5f0e6f

172.16.12.100	172.16.12.252	DNS	80 Standard query 0xf693 A client2.ctec.dmu.org
172.16.12.252	172.16.12.100	DNS	129 Standard query response 0xf693 A client2.ctec.dmu.org A 172.16.12.110 NS ns.ctec.dmu.org A ..
172.16.12.100	172.16.12.252	DNS	86 Standard query 0x3d44 PTR 110.12.16.172.in-addr.arpa
172.16.12.252	172.16.12.100	DNS	86 Standard query response 0x3d44 Server failure PTR 110.12.16.172.in-addr.arpa
172.16.12.100	172.16.12.252	DNS	86 Standard query 0x3d44 PTR 110.12.16.172.in-addr.arpa
172.16.12.252	172.16.12.100	DNS	86 Standard query response 0x3d44 Server failure PTR 110.12.16.172.in-addr.arpa
172.16.12.100	172.16.12.252	DNS	86 Standard query 0x6db6 PTR 110.12.16.172.in-addr.arpa
172.16.12.252	172.16.12.100	DNS	86 Standard query response 0x6db6 Server failure PTR 110.12.16.172.in-addr.arpa
172.16.12.100	172.16.12.252	DNS	86 Standard query 0x6db6 PTR 110.12.16.172.in-addr.arpa
172.16.12.252	172.16.12.100	DNS	86 Standard query response 0x6db6 Server failure PTR 110.12.16.172.in-addr.arpa
172.16.12.100	172.16.12.252	DNS	80 Standard query 0xe800 A client3.ctec.dmu.org
172.16.12.252	172.16.12.100	DNS	129 Standard query response 0xe800 A client3.ctec.dmu.org A 172.16.12.120 NS ns.ctec.dmu.org A ..
172.16.12.100	172.16.12.252	DNS	86 Standard query 0xe9bf PTR 120.12.16.172.in-addr.arpa
172.16.12.252	172.16.12.100	DNS	86 Standard query response 0xe9bf Server failure PTR 120.12.16.172.in-addr.arpa
172.16.12.100	172.16.12.252	DNS	86 Standard query 0xe9bf PTR 120.12.16.172.in-addr.arpa
172.16.12.252	172.16.12.100	DNS	86 Standard query response 0xe9bf Server failure PTR 120.12.16.172.in-addr.arpa
172.16.12.100	172.16.12.252	DNS	86 Standard query 0xe576 PTR 120.12.16.172.in-addr.arpa
172.16.12.252	172.16.12.100	DNS	86 Standard query response 0xe576 Server failure PTR 120.12.16.172.in-addr.arpa
172.16.12.100	172.16.12.252	DNS	86 Standard query 0xe576 PTR 120.12.16.172.in-addr.arpa
172.16.12.252	172.16.12.100	DNS	86 Standard query response 0xe576 Server failure PTR 120.12.16.172.in-addr.arpa
172.16.12.100	172.16.12.252	DNS	80 Standard query 0x564e A client4.ctec.dmu.org
172.16.12.252	172.16.12.100	DNS	125 Standard query response 0x564e No such name A client4.ctec.dmu.org SOA ns.ctec.dmu.org
172.16.12.100	172.16.12.252	DNS	93 Standard query 0xa3c2 A client4.ctec.dmu.org.ctec.dmu.org
172.16.12.252	172.16.12.100	DNS	138 Standard query response 0xa3c2 No such name A client4.ctec.dmu.org.ctec.dmu.org SOA ns.ctec.dmu.org



- DNS cache poisoning
 - data is distributed to caching resolvers as an authoritative origin server
- DNS responses are traditionally not cryptographically signed
- Domain names may be used to achieve spoofing
- Can use mitigation techniques
 - eg forward-confirmed reverse DNS to help validate DNS results



- . Who runs the Internet?
- . DNS
- DNS Mechanism
- DNS Messages

Q&A

Thank You!